



RTM View Shell

Security & Compliance Summary

Authentication, isolation, audit and data protection — at a glance

Business / stakeholder summary D-02 — for security reviewers and decision-makers

Edition EN · 2026-07-03 · RTM View Shell

Document revision history

This table lists the revision history of this document.

Version	Date	Summary of changes	Product release ID	Shipped-with (commit/barrier)
1.0	2026-07-03	Initial (regenerated)	RTM-REL-2026.06	(pending push)

Contents

Document revision history.....	2
Contents.....	3
1. Purpose.....	4
2. Authentication.....	4
3. Credential protection.....	4
4. Attack resistance.....	4
5. Multi-tenant isolation.....	4
6. Audit & accountability.....	4
7. Data protection.....	5
8. Secure-by-default posture.....	5
Appendix A — Controls at a glance.....	6

1. Purpose

This summary states, in one place and in plain terms, the security controls built into RTM View Shell and the guarantees they provide. It is intended for security reviewers, compliance teams and decision-makers. The configuration detail behind each control is in the Security Configuration Guide (A-04); this document is the executive view.

2. Authentication

- **Two surfaces, one identity.** The web application uses a hardened HttpOnly/Secure/same-site session cookie (30-min sliding, 8-h absolute). The optional REST API uses short-lived RSA-signed JWTs. Both share the same accounts, policy and audit.
- **Two-factor by e-mail.** A 6-digit one-time code (10-min validity, 3 attempts) can be required per user or made mandatory for an entire organisation.
- **Single Sign-On ready.** Per-tenant OIDC / SAML 2.0 / AD-LDAP, honouring provider-asserted MFA so users are not double-prompted.

3. Credential protection

- Passwords: minimum 12 characters, mixed complexity, last-10 history enforced, 90-day expiry — configurable per tenant.
- Stored only as salted PBKDF2-HMAC-SHA512 hashes; never logged, never reversible.
- API refresh tokens are stored hashed, delivered as host-only cookies, and rotated on every use; reuse of a revoked token revokes all of the user's tokens and is audited.

4. Attack resistance

- Account lockout after 5 failed attempts (15 minutes); rate limiting on the sign-in endpoint (10/min/IP).
- Uniform “Invalid username or password” errors prevent account and tenant enumeration.
- HTTPS / TLS 1.2+ only (weak ciphers disabled) and a full set of security response headers (CSP, HSTS, anti-framing, no-sniff, referrer, permissions). Anti-forgery on web forms; origin checks on the API.

5. Multi-tenant isolation

Each customer organisation (tenant) is isolated at the data layer: every query is automatically scoped to the active tenant, not merely hidden in the UI. The only bypass is a dedicated, audited path for legitimate platform-level access, which writes a cross-tenant access event every time. Caches, real-time channels and storage are all tenant-prefixed.

6. Audit & accountability

Every security-relevant action — sign-in success/failure with subtype, lockouts, token refresh and revocation, 2FA events, SSO sign-in, password and permission changes, and all tenant lifecycle actions — is written to an append-only audit log recording who, when (UTC), client IP and user-agent. The log cannot be edited or deleted through the application; it is read and export only, retained per tenant policy (365 days by default).

7. Data protection

- Secrets (connection strings, signing keys, e-mail and SSO credentials) are held outside source control in a vault or encrypted store; sensitive configuration is encrypted at rest.
- All timestamps stored in UTC; personal data minimised in logs (no passwords, no tokens).
- Soft-delete with retention windows for recoverability; tenant deletion purges data after a grace period.

8. Secure-by-default posture

Several defaults are deliberately restrictive: an empty resource permission list denies all (not allows all); a new tenant exposes nothing until access is granted; authorisation is enforced in the application layer at every request, not just in the interface. The architecture follows a clean, layered design with automated tests enforcing the dependency and isolation rules on every change.

Appendix A — Controls at a glance

Area	Control
Web session	HttpOnly+Secure+SameSite cookie; 30 min sliding / 8 h absolute; re-auth on role/tenant change
API tokens	RSA JWT 15 min; refresh 8 h, hashed, rotated; reuse → revoke-all
Passwords	12+ mixed; last-10 history; 90-day expiry; PBKDF2-SHA512
Two-factor	E-mail 6-digit OTP; per-user or mandatory per tenant
Brute-force	Lockout 5/15 min; rate-limit 10/min/IP; uniform errors
Transport	HTTPS TLS 1.2+; weak ciphers off; full security headers
Isolation	Per-tenant query scoping; audited bypass only; prefixed cache/RT/storage
Audit	Append-only; who/when/IP/agent; read+export only; 365-day default